

Kampus Merdeka
INDONESIA JAYA

Siliwangi University

Section 3

Software Security

 Information Security
Ir. Alam Rahmatulloh, S.T., M.T., MCE., IPM.

22/08/22 <https://youtube.com/@siloment> 1

1

Kampus Merdeka
INDONESIA JAYA

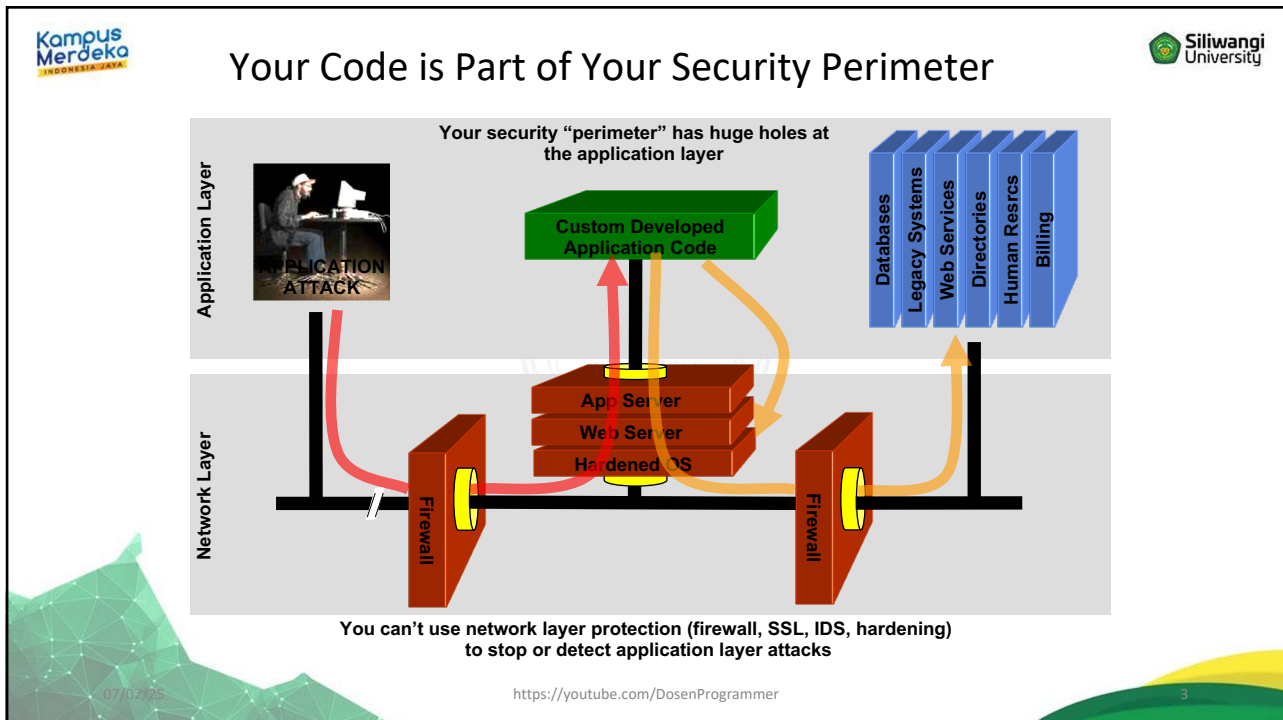
Siliwangi University

What is Software Security?

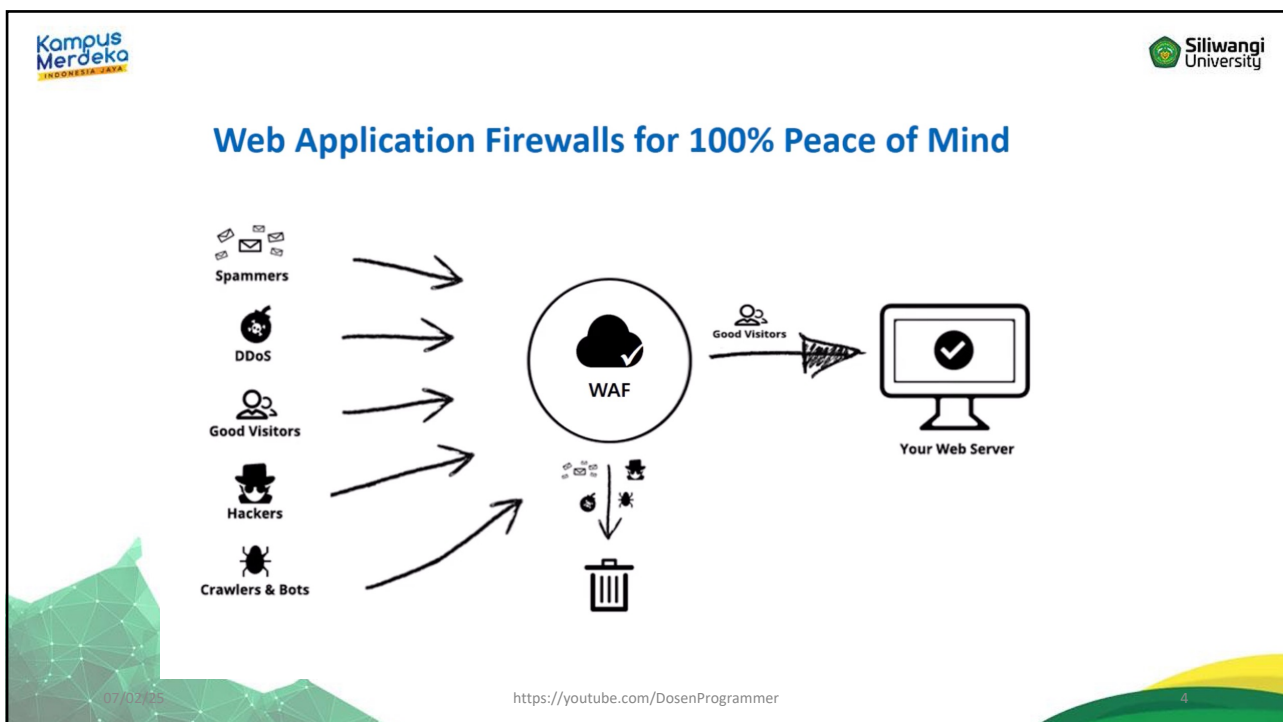
- Not Network Security
 - Securing the “custom code” that drives a web application
 - Securing libraries
 - Securing backend systems
 - Securing web and application servers
- Network Security Mostly **Ignores** the Contents of HTTP Traffic
 - Firewalls, SSL, Intrusion Detection Systems, Operating System Hardening, Database Hardening

07/07/25 <https://youtube.com/DosenProgrammer> 2

2



3



4

Why is it ours?

- Let's just think this through...
 - How likely is a successful web application attack?
 - Stunningly prevalent
 - Easy to exploit without special tools or knowledge
 - Little chance of being detected
 - Hundreds of thousands of developers, tiny fraction with security

07/02/25

<https://youtube.com/DosenProgrammer>

5

5

Why is it ours?

- Consequences?
 - Corruption or disclosure of database contents
 - Root access to web and application servers
Loss of authentication and access control for users
 - Defacement
 - Secondary attacks from your site
- Application Security is just as important as Network Security
 - Why does the vast majority of security money go to secure networks?

07/02/25

<https://youtube.com/DosenProgrammer>

6

6

Security is holistic

- Security is a holistic view
 - Physical
 - Badges must be checked
 - No Piggyback
 - Screensaver lock
 - Door lock/Restricted Area
 - Technological
 - Application
 - Operation System
 - Network
 - Policy & Procedure

07/02/25

<https://youtube.com/DosenProgrammer>

7

7

Vulnerability, Threat, Attack, and Control

- A **vulnerability** is a weakness in the security system
- A **threat** to a computing system is a set of circumstances that has the potential to cause loss or harm
A human who exploits a vulnerability perpetrates an **attack** on the system
- We use a **control** as a protective measure

07/02/25

<https://youtube.com/DosenProgrammer>

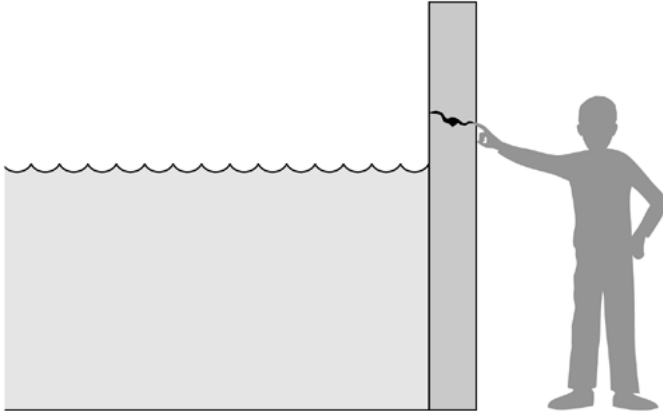
8

8

Kampus Merdeka
INDONESIA 2025

Siliwangi University

Vulnerability, Threat, Attack, and Control



07/02/25

<https://youtube.com/DosenProgrammer>

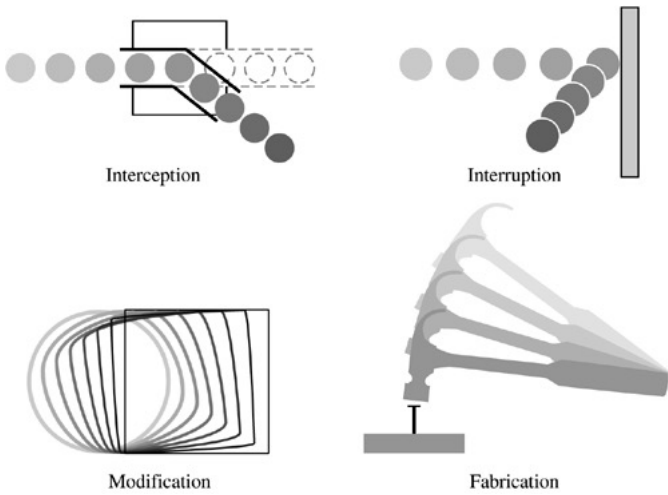
9

9

Kampus Merdeka
INDONESIA 2025

Siliwangi University

Information Security Threat



Interception

Interruption

Modification

Fabrication

07/02/25

<https://youtube.com/DosenProgrammer>

10

10

Security Control

- *prevent it*, by blocking the attack or closing the vulnerability
- *deter it*, by making the attack harder but not impossible
- *deflect it*, by making another target more attractive (or this one less so)
- *detect it*, either as it happens or some time after the fact
- *recover* from its effects

07/02/25

<https://youtube.com/DosenProgrammer>

11

11

Security Concepts

Menurut Garfinkel [Simson Garfinkel, "*PGP: Pretty Good Privacy*," O'Reilly & Associates, Inc., 1995.]

- **Confidentiality**
- **Integrity**
- **Availability**
- **Authentication**
- **Authorization**
- **Accounting**
- **Non-Repudiation**

07/02/25

<https://youtube.com/DosenProgrammer>

12

12

Confidentiality...FOS hal 17

- Defenisi : menjaga informasi dari orang yang tidak berhak mengakses.
- Privacy : lebih kearah data-data yang sifatnya privat , Contoh : e-mail seorang pemakai (*user*) tidak boleh dibaca oleh administrator.
- Confidentiality : berhubungan dengan data yang diberikan ke pihak lain untuk keperluan tertentu dan hanya diperbolehkan untuk keperluan tertentu tersebut.
- Contoh : data-data yang sifatnya pribadi (seperti nama, tempat tanggal lahir, social security number, agama, status perkawinan, penyakit yang pernah diderita, nomor kartu kredit, dan sebagainya) harus dapat diproteksi dalam penggunaan dan penyebarannya.
- Bentuk Serangan : usaha penyadapan (dengan program *sniffer*).
- Usaha-usaha yang dapat dilakukan untuk meningkatkan privacy dan confidentiality adalah dengan menggunakan teknologi kriptografi.

07/02/25

12 Software Security - Alam Rahmatulloh

<https://youtube.com/DosenProgrammer>

13

13

Message/Integrity

- Defenisi : informasi tidak boleh diubah tanpa seijin pemilik informasi.
- Contoh : e-mail di *intercept* di tengah jalan, diubah isinya, kemudian diteruskan ke alamat yang dituju.
- Bentuk serangan : Adanya virus, *trojan horse*, atau pemakai lain yang mengubah informasi tanpa ijin, "man in the middle attack" dimana seseorang menempatkan diri di tengah pembicaraan dan menyamar sebagai orang lain.

07/02/25

13 Software Security - Alam Rahmatulloh

<https://youtube.com/DosenProgrammer>

14

14

Availability

- Defenisi : berhubungan dengan ketersediaan informasi ketika dibutuhkan.
- Contoh hambatan :
 - “*denial of service attack*” (DoS attack), dimana server dikirim permintaan (biasanya palsu) yang bertubi-tubi atau permintaan yang diluar perkiraan sehingga tidak dapat melayani permintaan lain atau bahkan sampai *down*, *hang*, *crash*.
 - *mailbomb*, dimana seorang pemakai dikirim e-mail bertubi-tubi (katakan ribuan e-mail) dengan ukuran yang besar sehingga sang pemakai tidak dapat membuka e-mailnya atau kesulitan mengakses e-mailnya.

07/02/25

<https://youtube.com/DosenProgrammer>

15

15

Authentication

- Identity Verification
- How can Bob be sure that he is communicating with Alice?
- Three General Ways:
 - Something you ***know*** (i.e., ***Passwords***)
 - Something you ***have*** (i.e., ***Tokens***)
 - Something you ***are*** (i.e., ***Biometrics***)

07/02/25

<https://youtube.com/DosenProgrammer>

16

16

Something you KNOW

- Example: Passwords
 - Pros:
 - Simple to implement
 - Simple for users to understand
 - Cons:
 - Easy to crack (unless users choose strong ones)
 - Passwords are reused many times
- One-time Passwords (OTP): different password used each time, but it is difficult for user to remember all of them

07/02/25

<https://youtube.com/DosenProgrammer>

17

17

Something you KNOW

- Example: Passwords
 - Pros:
 - Simple to implement
 - Simple for users to understand
 - Cons:
 - Easy to crack (unless users choose strong ones)
 - Passwords are reused many times
- One-time Passwords (OTP): different password used each time, but it is difficult for user to remember all of them



07/02/25

<https://youtube.com/DosenProgrammer>

18

18

Something you *HAVE*

- OTP Cards (e.g. SecurID): generates new password each time user logs in
- Smart Card: tamper-resistant, stores secret information, entered into a card-reader
- Token / Key (i.e., iButton)
- ATM Card
- Strength of authentication depends on difficulty of forging

07/07/25

<https://youtube.com/DosenProgrammer>

19

19

Something you *ARE*

- Biometrics



Technique	Effectiveness	Acceptance
Palm Scan	1	6
Iris Scan	2	1
Retina Scan	3	7
Fingerprint	4	5
Voice ID	5	3
Facial Recognition	6	4
Signature Dynamic	7	2

- Pros: “raises the bar”
- Cons: false negatives/positives, social acceptance, key management
 - false positive: authentic user rejected
 - false negative: impostor accepted

07/07/25

<https://youtube.com/DosenProgrammer>

20

20

Multi-Authentication

- Two-factor Authentication: Methods can be combined (i.e. ATM card & PIN)
- Who is authenticating who?
 - Person-to-computer?
 - Computer-to-computer?
- Three types (e.g. SSL):
 - Client Authentication: server verifies client's id
 - Server Authentication: client verifies server's id
 - Mutual Authentication (Client & Server)
- Authenticated user is a "Principal"

07/02/25

<https://youtube.com/DosenProgrammer>

21

21

Authentication: Proof That You are Who You Claim to Be

- Sebelum bisa memberikan layanan kepada pengguna, penyedia layanan perlu tahu siapa anda.

07/02/25

<https://youtube.com/DosenProgrammer>

22

22

Authorization: What are You Allowed to Do

- Authorization adalah proses menentukan apa sajakah layanan yang bisa dinikmati pengguna yang telah jelas identitasnya (authenticated user).

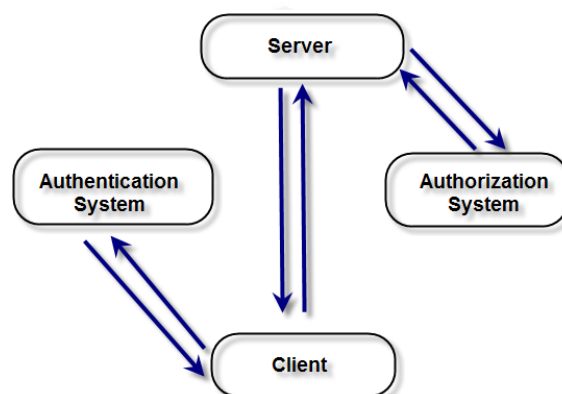
07/02/25

<https://youtube.com/DosenProgrammer>

23

23

Client, Server, Authentication, Authorization



07/02/25

<https://youtube.com/DosenProgrammer>

24

24

Access Control Lists (ACLs)

- Set of three-tuples
 - <User, Resource, Privilege>
 - Specifies which users are allowed to access which resources with which privileges
- Privileges can be assigned based on roles (e.g. admin)

Table 1-1. A Simple ACL

User	Resource	Privilege
Alice	/home/Alice/*	Read, write, execute
Bob	/home/Bob/*	Read, write, execute

07/02/25

<https://youtube.com/DosenProgrammer>

25

25

Access Control Models

- ACLs used to implement these models
- *Mandatory*: computer system decides exactly who has access to which resources
- *Discretionary* (e.g. UNIX): users are authorized to determine which other users can access files or other resources that they create, use, or own
- *Role-Based* (Non-Discretionary): user's access & privileges determined by role

07/02/25

<https://youtube.com/DosenProgrammer>

26

26

Kampus Merdeka
INDONESIA JAYA

Siliwangi University

Bell-LaPadula Model

- Classifications:
 - Top Secret
 - Secret
 - Confidential
 - Unclassified
- 3 Rules/Properties
 - Simple property
 - *-property (confinement)
 - Tranquility property

READ



"No Read Up"

WRITE



"No Write Down"

07/02/25

<https://youtube.com/DosenProgrammer>

27

27

Kampus Merdeka
INDONESIA JAYA

Siliwangi University

Confidentiality

- Goal: Keep the contents of communication or data on storage secret
- Example: Alice and Bob want their communications to be secret from Eve
- Key – a secret shared between Alice & Bob
- Sometimes accomplished with
 - Cryptography, Steganography, Access Controls, Database Views

07/02/25

<https://youtube.com/DosenProgrammer>

28

28

Message/Data Integrity

- Data Integrity = No Corruption
- *Man in the middle attack*: Has Mallory tampered with the message that Alice sends to Bob?
- *Integrity Check*: Add redundancy to data/messages
- Techniques:
 - Hashing (MD5, SHA-1, ...), Checksums (CRC...)
 - Message Authentication Codes (MACs)
- Different From Confidentiality:
 - A -> B: "The value of x is 1" (not secret)
 - A -> M -> B: "The value of x is 10000" (BAD)
 - A -> M -> B: "The value of y is 1" (BAD)

07/02/25

<https://youtube.com/DosenProgrammer>

29

29

Accountability

- Able to determine the attacker or principal
- Logging & Audit Trails
- Requirements:
 - Secure Timestamping (OS vs. Network)
 - Data integrity in logs & audit trails, must not be able to change trails, or be able to detect changes to logs
 - Otherwise attacker can cover their tracks

07/02/25

<https://youtube.com/DosenProgrammer>

30

30

Availability

- Uptime, Free Storage
 - Ex. Dial tone availability, System downtime limit, Web server response time
- Solutions:
 - Add redundancy to remove single point of failure
 - Impose “limits” that legitimate users can use
- Goal of DoS (Denial of Service) attacks are to reduce availability
 - Malware used to send excessive traffic to victim site
 - Overwhelmed servers can't process legitimate traffic

07/02/25

<https://youtube.com/DosenProgrammer>

31

31

Non-Repudiation

- Undeniability of a transaction
- Alice wants to prove to Trent that she did communicate with Bob
- Generate evidence / receipts (digitally signed statements)
- Often not implemented in practice, credit-card companies become de facto third-party verifiers

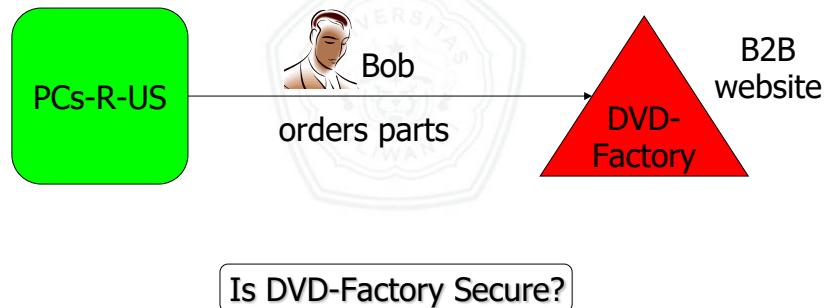
07/02/25

<https://youtube.com/DosenProgrammer>

32

32

Concepts at Work (1)



07/02/25

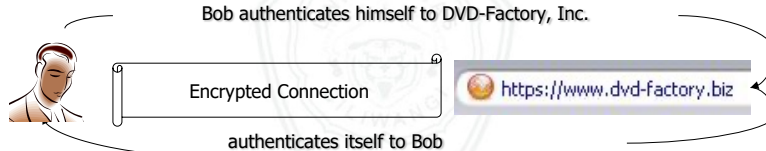
<https://youtube.com/DosenProgrammer>

33

33

Concepts at Work (2)

- Availability:
 - DVD-Factory ensures its web site is running 24-7
- Authentication:
 - Bob authenticates himself to DVD-Factory, Inc.
- Confidentiality:
 - Bob's browser and DVD-Factory web server set up an encrypted connection (lock on bottom left of browser)



07/02/25

<https://youtube.com/DosenProgrammer>

34

34

Concepts at Work (3)

- Authorization:
 - DVD-Factory web site consults DB to check if Bob is authorized to order widgets on behalf of PCs-R-U's
- Message / Data Integrity:
 - Checksums are sent as part of each TCP/IP packets exchanged (+ SSL uses MACs)
- Accountability:
 - DVD-Factory logs that Bob placed an order for Sony DVD-R 1100
- Non-Repudiation:
 - Typically not provided w/ web sites since TTP req'd.

07/02/25

<https://youtube.com/DosenProgrammer>

35

35

Summary

- Technological Security In Context
- Seven Key Security Concepts
- DVD-Factory Example:
Security Concepts at Work

07/02/25

<https://youtube.com/DosenProgrammer>

36

36

- Warming up... with codes



07/02/25

<https://youtube.com/DosenProgrammer>

37

37



07/02/25

<https://youtube.com/DosenProgrammer>

38

38





A Simple Web Server

To illustrate what can go wrong if we do not design for security in our web applications from the start, consider a simple web server implemented in Java.

All this program does is serve documents using HTTP.

We will walkthrough the code in the following slides.

07/02/25 <https://youtube.com/DosenProgrammer> 39

39





Some Preliminaries...

- A typical HTTP request that a browser makes to a web server:
`Get / HTTP/1.0`
- When the server receives this request for filename / (which means the *root* document on the web server), it attempts to load index.html. It sends back:
`HTTP/1.0 200 OK`
followed by the document contents.

07/02/25 <https://youtube.com/DosenProgrammer> 40

40

SimpleWebServer: main()

```

/* This method is called when the program is run
from the command line. */

public static void main (String argv[]) throws
    Exception {
    /* Create a SimpleWebServer object, and run it */
    SimpleWebServer sws = new SimpleWebServer();
    sws.run();
}

```

07/02/25

<https://youtube.com/DosenProgrammer>

41

41

SimpleWebServer Object

```

public class SimpleWebServer {

    /* Run the HTTP server on this TCP port. */
    private static final int PORT = 8080;
    /* The socket used to process incoming connections from web clients */
    private static ServerSocket dServerSocket;

    public SimpleWebServer () throws Exception {
        dServerSocket = new ServerSocket (PORT);
    }
    public void run() throws Exception {
        while (true) {
            /* wait for a connection from a client */
            Socket s = dServerSocket.accept();
            /* then process the client's request */
            processRequest(s);
        }
    }
}

```

07/02/25

<https://youtube.com/DosenProgrammer>

42

42

SimpleWebServer: processRequest

1

```

/* Reads the HTTP request from the client, and responds with the file the
user requested or a HTTP error code. */

public void processRequest(Socket s) throws Exception {
    /* used to read data from the client */
    BufferedReader br =
        new BufferedReader (new InputStreamReader (s.getInputStream()));

    /* used to write data to the client */
    OutputStreamWriter osw =
        new OutputStreamWriter (s.getOutputStream());

    /* read the HTTP request from the client */
    String request = br.readLine();
    String command = null;
    String pathname = null;

```

07/02/25

<https://youtube.com/DosenProgrammer>

43

43

SimpleWebServer: processRequest

2

```

parse the HTTP request */
StringTokenizer st =
    new StringTokenizer (request, " ");

command = st.nextToken();
pathname = st.nextToken();

if (command.equals("GET")) {
    /* if the request is a GET
    try to respond with the file
    the user is requesting */
    serveFile (osw,pathname);
} else {
    /* if the request is a NOT a GET,
    return an error saying this server
    does not implement the requested command */
    osw.write ("HTTP/1.0 501 Not Implemented\n\n"); }
    /* close the connection to the client */
    osw.close();

```

07/02/25

<https://youtube.com/DosenProgrammer>

44

44

SimpleWebServer: serveFile

1

```

public void serveFile (OutputStreamWriter osw,
    String pathname) throws Exception {
    FileReader fr=null;
    int c=-1;
    StringBuffer sb = new StringBuffer();

    /* remove the initial slash at the beginning
    of the pathname in the request */
    if (pathname.charAt(0)=='/')
        pathname=pathname.substring(1);

    /* if there was no filename specified by the client,
    serve the "index.html" file */
    (pathname.equals(""))
        pathname="index.html";

```

07/02/25

<https://youtube.com/DosenProgrammer>

45

45

SimpleWebServer: serveFile

2

```

/* try to open file specified by pathname */
try {
    fr = new FileReader (pathname);
    c = fr.read(); }
catch (Exception e) {

/* if the file is not found,
return the appropriate HTTP response code */
osw.write ("HTTP/1.0 404 Not Found\n\n");
return;
}

```

07/02/25

<https://youtube.com/DosenProgrammer>

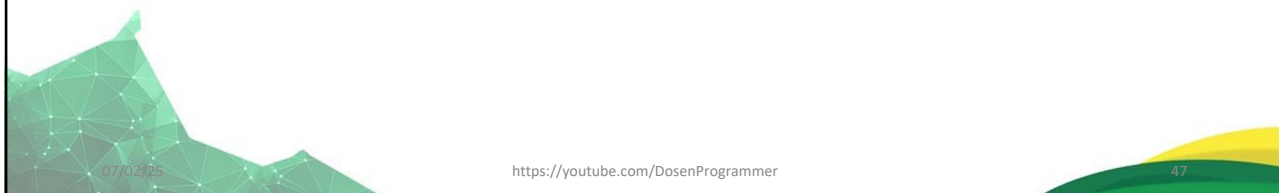
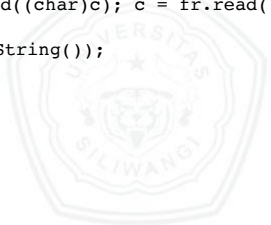
46

46



SimpleWebServer: serveFile
3





07/02/25

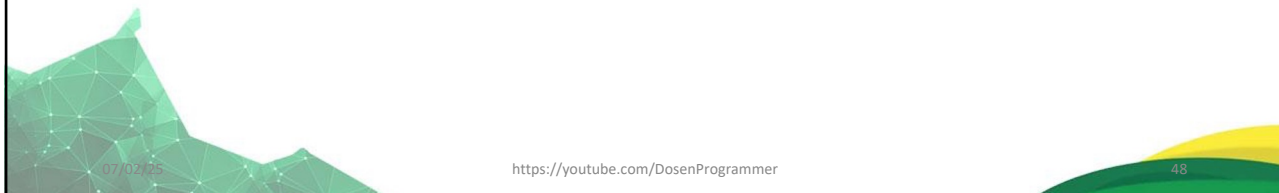
<https://youtube.com/DosenProgrammer>

47

47







07/02/25

<https://youtube.com/DosenProgrammer>

48

48

What Can Go Wrong?

Denial of Service (DoS):

- An attacker makes a web server unavailable.
- Example: an online bookstore's web server crashes and the bookstore loses revenue

07/02/25

<https://youtube.com/DosenProgrammer>

49

49

DoS on SimpleWebServer?

Just send a carriage return as the first message instead of a properly formatted GET message...

07/02/25

<https://youtube.com/DosenProgrammer>

50

50

DoS on SimpleWebServer?

processRequest() :

```
/* read the HTTP request from the client */
String request = br.readLine();
String command = null;
String pathname = null;

/* parse the HTTP request */
StringTokenizer st =
    new StringTokenizer (request, " ");

command = st.nextToken();
pathname = st.nextToken();
```

07/02/25

<https://youtube.com/DosenProgrammer>

51

51

DoS on SimpleWebServer?

- The web server crashes
- Service to all subsequent clients is denied until the web server is restarted

07/02/25

<https://youtube.com/DosenProgrammer>

52

52

How Do We Fix This?

- *The web server should immediately disconnect from any web client that sends a malformed HTTP request to the server.*
- The programmer needs to carefully handle exceptions to deal with malformed requests.

07/02/25

<https://youtube.com/DosenProgrammer>

53

53

How would you fix this code?

processRequest() :

```
/* read the HTTP request from the client */
String request = br.readLine();
String command = null;
String pathname = null;

/* parse the HTTP request */
StringTokenizer st =
    new StringTokenizer (request, " ");

command = st.nextToken();
pathname = st.nextToken();
```

07/02/25

<https://youtube.com/DosenProgrammer>

54

54

A possible solution

```

/* read the HTTP request from the client */
String request = br.readLine();
String command = null;
String pathname = null;
try {
    /* parse the HTTP request */
    StringTokenizer st =
        new StringTokenizer (request, " ");
    command = st.nextToken();
    pathname = st.nextToken();
} catch (Exception e) {
    osw.write ("HTTP/1.0 400 Bad Request\n\n");
    osw.close();
    return;
}

```

07/02/25

<https://youtube.com/DosenProgrammer>

55

55

Importance of “Careful” Exception Handling

- Error messages and observable behavior can tip off an attacker to vulnerabilities
- Fault Injection: Providing a program with input that it does not expect (as in the CR for SimpleWebServer) and observing behavior

07/02/25

<https://youtube.com/DosenProgrammer>

56

56

Careful Exception Handling

- Two possible designs for


```
int checkPassword (String username, String password)
```
- The function could fail, so what exception should the function return?
 - 1) ERROR_ACCESS_DENIED
ERROR_PASS_FILE_NOT_FOUND
ERROR_OUT_OF_MEMORY
NO_ERROR_ACCESS_ALLOWED
 - 2) NO_ERROR ERROR

```
int getError ()
```

Be careful to not provide more information to a user than is needed.

07/02/25

<https://youtube.com/DosenProgrammer>

57

57

Careful Exception Handling

- ```
int result = checkPassword (...)
if (result == ERROR_ACCESS_DENIED) {
 abort();
} else {
 // Complete login
}
```
- Problem: `result != ERROR_ACCESS_DENIED` does not infer `ERROR_ACCESS_ALLOWED`
  - Result could have been:  
`ERROR_PASS_FILE_NOT_FOUND` or  
`ERROR_OUT_OF_MEMORY` !

07/02/25

<https://youtube.com/DosenProgrammer>

58

58

## Teaching Wisdom

- Effective exception handling is essential in designing security in from the start
- Next time, we look at other vulnerabilities and threats in Web Programming

07/02/25

<https://youtube.com/DosenProgrammer>

59

59

**HEY! CAN YOU  
KEEP A SECRET?!!**



07/02/25

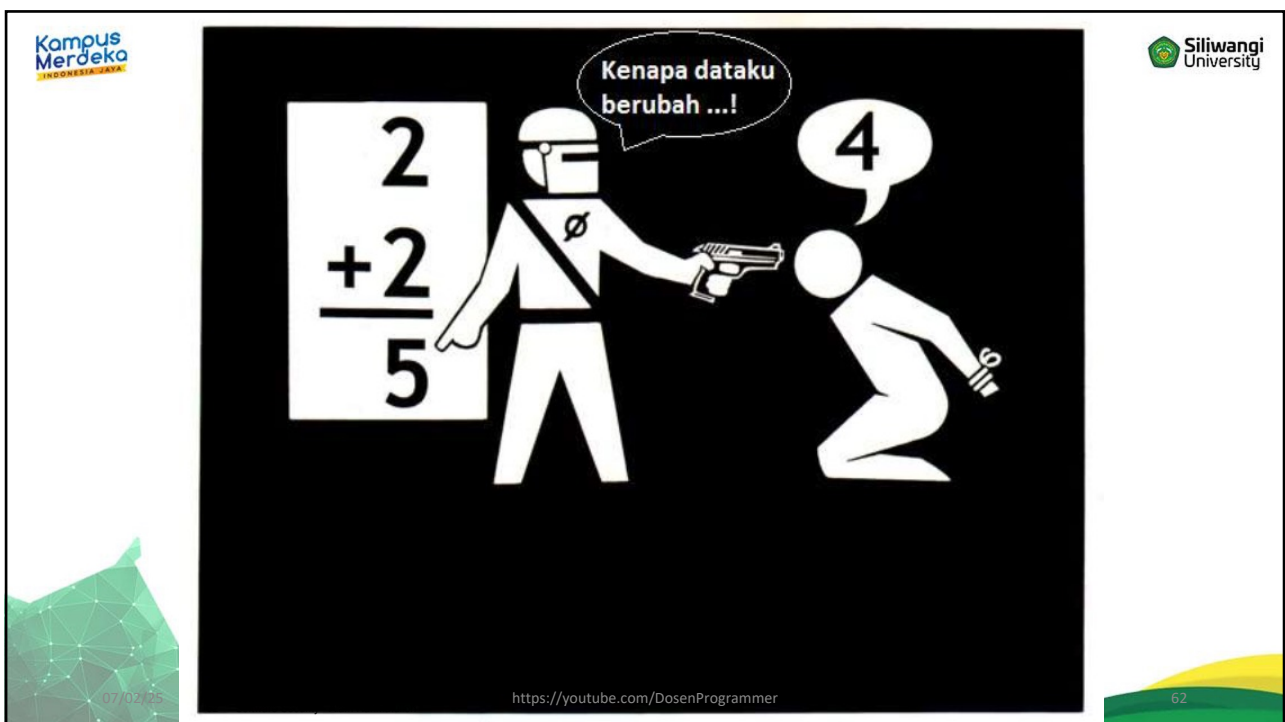
<https://youtube.com/DosenProgrammer>

60

60



61



62



63

|       | File1 | File2     | File3     | Sensitivity |
|-------|-------|-----------|-----------|-------------|
| User3 | RW    | RW        | RW        |             |
| User2 | RW    | RW        | No Access |             |
| User1 | RW    | No Access | No Access |             |

User Levels

Kampus Merdeka  
INDONESIA JAYA

Siliwangi University

07/02/25

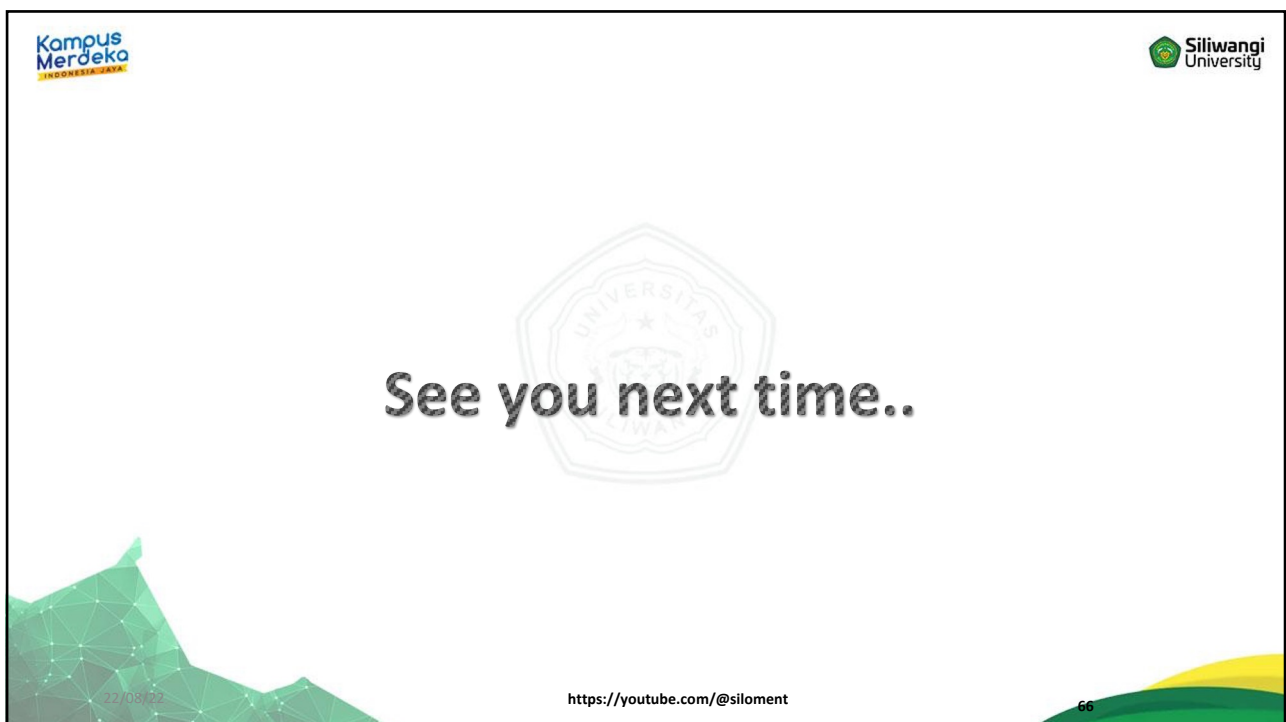
<https://youtube.com/DosenProgrammer>

64

64



65



66